

ADQUISICIÓN E INTEGRIDAD

de Evidencia Digital

Módulo Informática Forense // Sesión 2

[QBit]

La Adquisición Física (Nivel 0)



Definición: Captura binaria completa del soporte, incluyendo tanto el Espacio Asignado como el No Asignado.



Bloques, no archivos: En la adquisición a bajo nivel no hablamos de archivos lógicos, hablamos de bloques de disco.



El objetivo: Obtener una réplica forense matemáticamente exacta que sirva como prueba en un tribunal.

Bit-a-Bit vs. Copia Lógica

- > **Copia lógica:** Solo extrae archivos visibles para el Sistema Operativo. Pierde datos borrados y metadatos vitales de sistema.
- > **Copia física (Bit-a-bit):** Captura sectores completos del soporte independientemente del sistema de archivos.
- > **Fundamental:** La adquisición física es la única que captura el *slack space* y los registros de sistema ocultos, vitales para el DFIR.



El Riesgo de la Adquisición



Contaminación

Cualquier escritura en el dispositivo original contamina la prueba. Modificar un solo bit altera drásticamente la firma final.



El SO es intrusivo

El sistema operativo, al conectar el disco, lo monta automáticamente, altera timestamps y crea archivos ocultos del sistema.



La Solución

Implementación estricta de bloqueadores de escritura (Write Blockers) mediante Hardware o Software forense especializado.

La Integridad como Ley

La evidencia digital es mutable por definición. Nuestra labor es garantizar que lo extraído es idéntico a lo que había en la escena del incidente.

El Estándar: Algoritmos Hash

256

BITS DE SEGURIDAD (SHA-256)

Criptografía Aplicada

Los algoritmos determinísticos garantizan que el mismo *input* genera siempre el mismo *output*. Por el **efecto avalancha**, modificar un solo bit cambia todo el hash. MD5 y SHA-1 son vulnerables a colisiones y ya no sirven para peritajes serios. SHA-256 es el estándar actual del NIST para garantizar evidencia en imágenes .dd.

La Cadena de Custodia

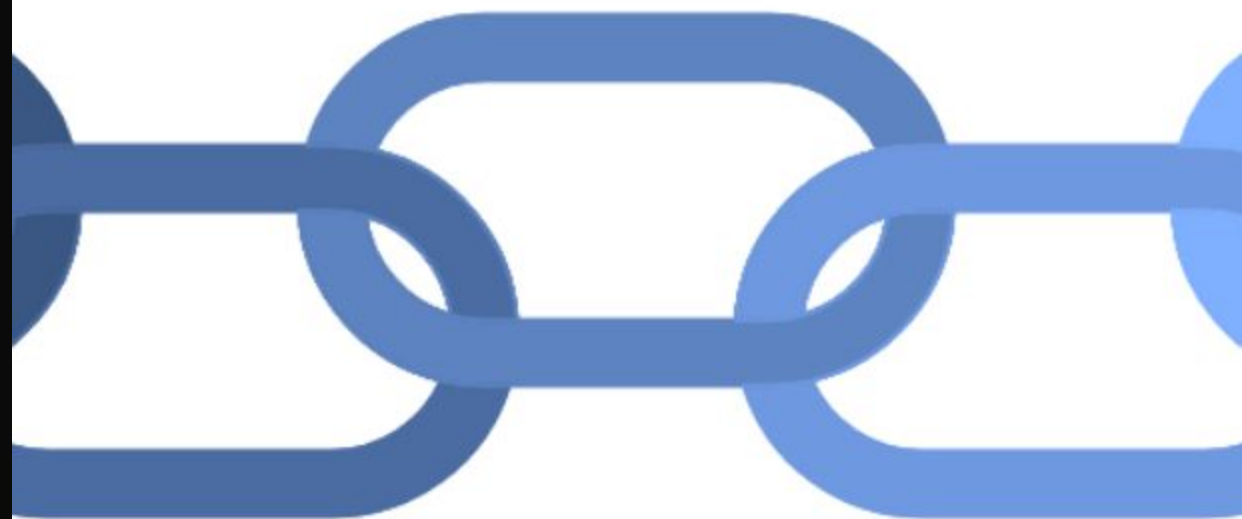
Documentación técnica: ¿Quién adquirió? ¿Con qué equipo? ¿Qué hash obtuvo al inicio y al final?

La cadena pericial es tan fuerte como su eslabón más débil. Si la trazabilidad se rompe en el laboratorio o durante el transporte, la prueba pierde su valor legal.

El Hash de la evidencia debe registrarse **antes y después** de cualquier movimiento o análisis.

Chain of Custody

Incident Response



Legal Admissibility

Data Breach
Investigation

Logs Forenses (Auditoría)

- > No basta con clonar el disco. Hay que registrar absolutamente todo el proceso técnico ejecutado.
- > **Información necesaria:** Timestamp exacto, comando utilizado, dispositivo de origen, dispositivo de destino y reporte de errores.
- > Una evidencia **sin log de auditoría** es una evidencia que no tiene ningún respaldo frente a un perito de contraparte.

```
PS C:\Users\Penjaga\Downloads\hayabusa-2.16.0-win-x64> .\hayabusa-2.16.0-win-x64.exe

HAYABUSA
by Yamato Security

Hayabusa v2.16.0 - FIRSTCON24 Release
Yamato Security (https://github.com/Yamato-Security/hayabusa - @SecurityYamato)

Usage:
  hayabusa.exe <COMMAND> [OPTIONS]
  hayabusa.exe help <COMMAND> or hayabusa.exe <COMMAND> -h

Commands:
  computer-metrics  Print computer name metrics
  csv-timeline      Save the timeline in CSV format
  eid-metrics       Print event ID metrics
  json-timeline     Save the timeline in JSON/JSONL format
  level-tuning      Tune alert levels (default: ./rules/config/level_tuning.txt)
  list-contributors Print the list of contributors
  list-profiles     List the output profiles
  logon-summary     Print a summary of successful and failed logons
  pivot-keywords-list Create a list of pivot keywords
  search            Search all events by keyword(s) or regular expression
  set-default-profile Set default output profile
  update-rules      Update to the latest rules in the hayabusa-rules github repository
  help             Print this message or the help of the given subcommand(s)
```


El Core: dc3dd

Herramienta Evolucionada

dc3dd es la sucesora forense de la clásica herramienta dd de Unix. Su ventaja clave es proveer reportes de progreso en vivo y cálculo/validación de hash *on-the-fly* (en línea). Sintaxis base: if= (Input File) vs of= (Output File).

Anatomía del Comando

hash=sha256: Calcula el checksum en vuelo sin doble lectura.

log=archivo.txt: Mantiene la auditoría del proceso completo.

rec=off: Detiene la copia ante errores críticos para no estresar ni destruir el soporte físico dañado.

Montaje Forense & Loop Devices



Loop Devices

El archivo .dd es un contenedor estático. El Loop Device engaña al SO para que lo trate como un disco físico real (losetup -P).



Montaje (ro)

Utilizar el flag -o ro (Read Only) protege la evidencia a nivel kernel, impidiendo escrituras incluso a usuarios root.



Mapeado

Diferencia crítica: Entender que loop0 es el disco entero, mientras que loop0p1 representa las particiones montables.

Entornos Estériles

Aislamiento Total: Todo análisis debe realizarse en Máquinas Virtuales dedicadas. El Host principal jamás debe interactuar con el contenedor de la evidencia. Las redes virtuales del entorno de laboratorio deben estar **estrictamente desconectadas** del exterior o de internet.

Para almacenamiento en frío, usar sistemas de archivos robustos (ZFS/EXT4) y realizar *hashing periódico* para prevenir corrupción por bit rot.



Fallos Comunes & Anti-Forensics



Errores humanos: Adquirir o sobrescribir el dispositivo equivocado (ej. confundir sda con sdb), no verificar el hash, o trabajar sin bloqueadores.



Tácticas Anti-Forensics: Atacantes borrando datos o formateando.



La respuesta: La adquisición física no discrimina. Captura el *Unallocated space*. Si no hubo una sobrescritura sistemática (wiping), los datos siguen allí.

PREGUNTAS Y DEBATE

Adquirir sin corromper. Analizar sin modificar.

¿Qué hacemos si el soporte tiene sectores físicos defectuosos?